EH Individual Portfolio

Cyber Security and Digital Forensics

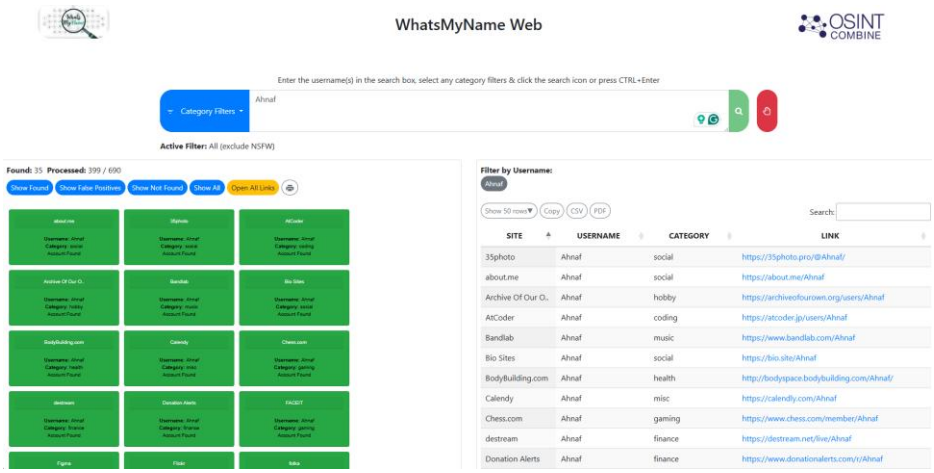
Ahnaf Ahmed

Lab2

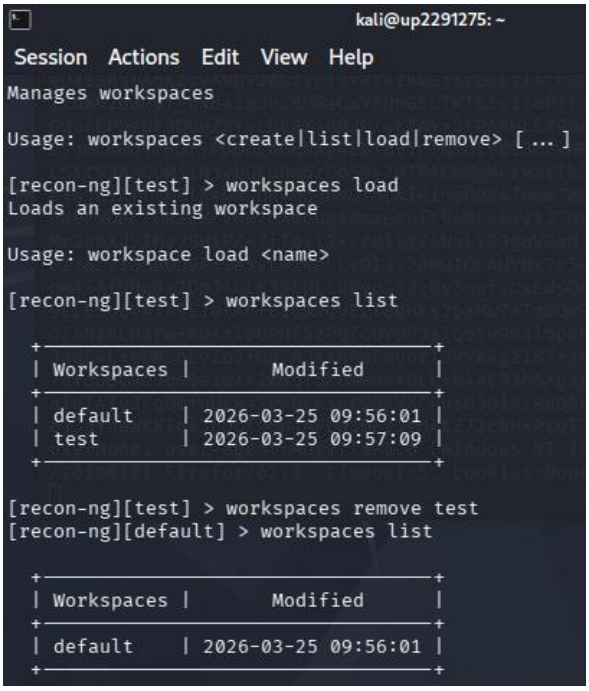
Passive reconnaissance

Q1.1: What is the value of doing username searches and account enumeration?

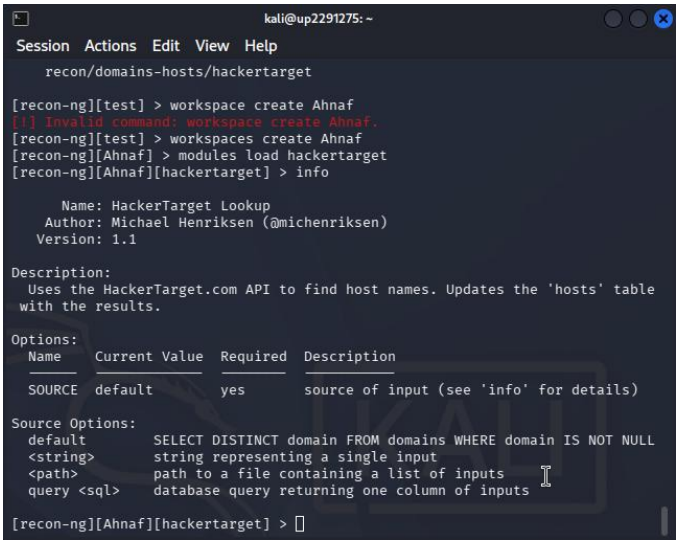
Help to identify valid user accounts and assess how much information a system exposes during authentication, which could aid further attacks.



Q1.2: How can you display the available workspaces? How can you remove a workspace?

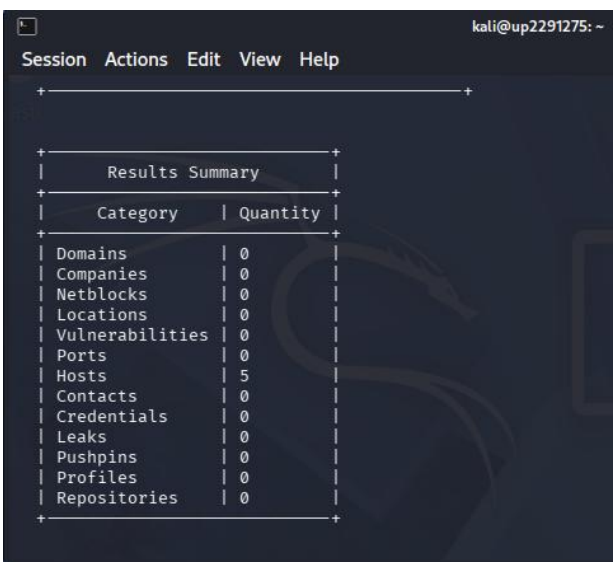


Q1.3: What information is available for this module?

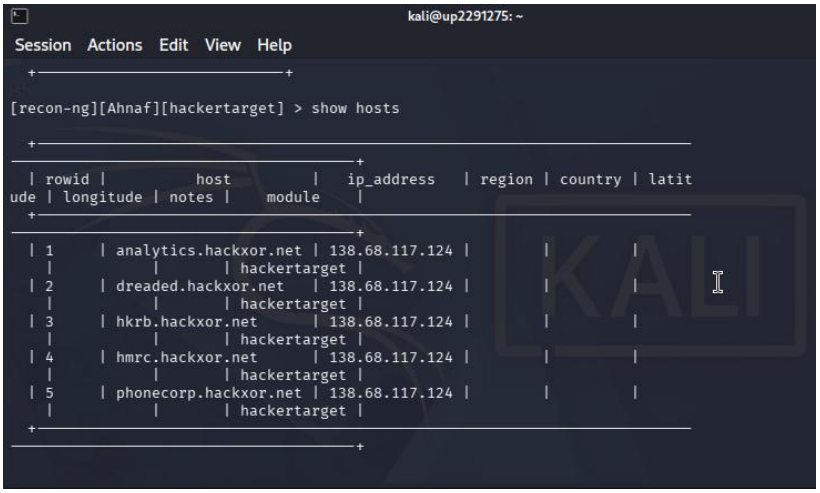


```
kali@up2291275: ~
Session  Actions  Edit  View  Help
    recon/domains-hosts/hackertarget

[recon-ng][test] > workspace create Ahnaf
[!] Invalid command: workspace create Ahnaf.
[recon-ng][test] > workspaces create Ahnaf
[recon-ng][Ahnaf] > modules load hackertarget
[recon-ng][Ahnaf][hackertarget] > info

      Name: HackerTarget Lookup
    Author: Michael Henriksen (@michenriksen)
   Version: 1.1

Description:
  Uses the HackerTarget.com API to find host names. Updates the 'hosts' table
 with the results.

Options:
  Name    Current Value  Required  Description
  ------  -------------  --------  -----------
  SOURCE  default        yes       source of input (see 'info' for details)

Source Options:
  default        SELECT DISTINCT domain FROM domains WHERE domain IS NOT NULL
  <string>       string representing a single input
  <path>         path to a file containing a list of inputs
  query <sql>    database query returning one column of inputs

[recon-ng][Ahnaf][hackertarget] >
```

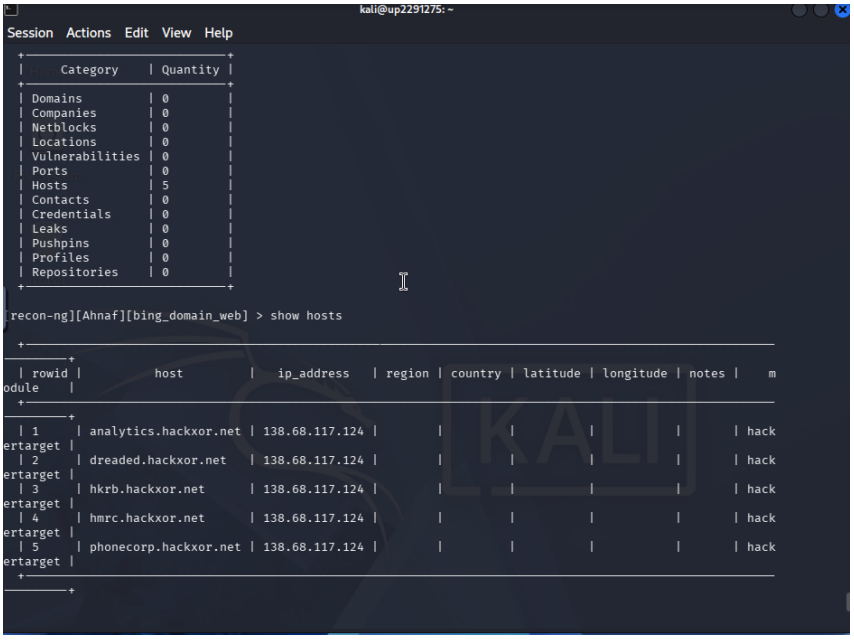
Q1.4: What is the Recon-ng data label for the subdomains that have been listed? How many were discovered?



```
kali@up2291275: ~
Session  Actions  Edit  View  Help

+------------------------------+
|      Results Summary         |
+------------------------------+
|     Category     | Quantity  |
+------------------------------+
| Domains          | 0         |
| Companies        | 0         |
| Netblocks        | 0         |
| Locations        | 0         |
| Vulnerabilities  | 0         |
| Ports            | 0         |
| Hosts            | 5         |
| Contacts         | 0         |
| Credentials      | 0         |
| Leaks            | 0         |
| Pushpins         | 0         |
| Profiles         | 0         |
| Repositories     | 0         |
+------------------------------+
```



Q1.5: How many subdomains did the module find? How does this compare to the hackertarget module?



Q1.6: Reflection Questions

You have experienced the use of several OSINT tools and resources in this lab. There are many more. The best way to learn how to use OSINT in your pentesting practice is to experiment until you find tools and approaches that work for you.

1. **What do you think about the recon-ng workspaces feature? How could you use it?**

The workspaces feature allows you to perform reconnaissance on each target separately which allows you to organise findings effectively with no overlapping with another target.

2. **2. Recon-ng uses a modular framework architecture. Do modules simplify using the Recon-ng tool? If so, how?**

Yes, because modules provide pre-built functionality for specific reconnaissance tasks such as emails associated with domains, retrieving IP information, retrieving phone numbers associated with domains etc.

Domain Enumeration

Q2.1: Which set keyword would you use to query for the mail server mx record within a domain

```
set keyword[=value]
        This  command is used to change state information that affects
        the lookups. Valid keywords are:
```

Set type = mx

Q2.2: What are the IPv4 addresses of the primary DNS server (dns1)

```
kali@up2291275: ~
Session  Actions  Edit  View  Help
No whois server is known for this kind of object.

┌──(kali㉿up2291275)-[~]
└─$ nslookup
> set type=ns
> port.ac.uk
Server:         127.0.0.11
Address:        127.0.0.11#53

Non-authoritative answer:
port.ac.uk      nameserver = dns0.port.ac.uk.
port.ac.uk      nameserver = dns1.port.ac.uk.

Authoritative answers can be found from:
>

┌──(kali㉿up2291275)-[~]
└─$ nslookup dns1.port.ac.uk
Server:         127.0.0.11
Address:        127.0.0.11#53

Non-authoritative answer:
Name:   dns1.port.ac.uk
Address: 148.197.255.1


┌──(kali㉿up2291275)-[~]
└─$
```

148.197.255.1

Q2.3: What is the IP address range for the IPv4 addresses allocated to UoP? The dns1.port.ac.uk server is addressed within this block.

```
kali@up2291275: ~
Session  Actions  Edit  View  Help
% This is the RIPE Database query service.
% The objects are in RPSL format.
%
% The RIPE Database is subject to Terms and Conditions.
% See https://docs.db.ripe.net/terms-conditions.html

% Note: this output has been filtered.
%       To receive output for a database update, use the "-B" flag.

% Information related to '148.197.0.0 - 148.197.255.255'

% Abuse contact for '148.197.0.0 - 148.197.255.255' is 'irt@jisc.ac.uk'

inetnum:        148.197.0.0 - 148.197.255.255
netname:        PORT-UNI-LINR
descr:          ISO
descr:          St. Andrew's Court, St. Michael's Road
descr:          Portsmouth, Hants PO1 2PR
country:        GB
org:            ORG-UOP9-RIPE
admin-c:        AM16861-RIPE
admin-c:        MM25422-RIPE
admin-c:        JH6051-RIPE
tech-c:         MM3482-RIPE
tech-c:         DE367-RIPE
status:         LEGACY
remarks:        Please send security issues to the abuse@port.ac.uk address w
here it will be appropriately
```

148.197.0.0-148.197.255.255

Q2.4: What is the difference between the default record types queried by Dig and those queried by Nslookup?

nslookup queries both A and AAAA records whereas dig only queries A by default.

Q2.5: Examine the output returned from the dig command. What type of device do you think is assigned the 72.163.1.1 address?

```
kali@up2291275: ~
Session  Actions  Edit  View  Help

┌──(kali㉿up2291275)-[~]
└─$ dig 72.163.1.1

; <<>> DiG 9.20.18-1-Debian <<>> 72.163.1.1
;; global options: +cmd
;; Got answer:
;; ->>HEADER<<- opcode: QUERY, status: NXDOMAIN, id: 4970
;; flags: qr rd ra; QUERY: 1, ANSWER: 0, AUTHORITY: 1, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 65494
;; QUESTION SECTION:
;72.163.1.1.                    IN      A

;; AUTHORITY SECTION:
.                       86400   IN      SOA     a.root-servers.net. nstld.ver
isign-grs.com. 2026040600 1800 900 604800 86400

;; Query time: 5 msec
;; SERVER: 127.0.0.11#53(127.0.0.11) (UDP)
;; WHEN: Mon Apr 06 08:23:30 UTC 2026
;; MSG SIZE  rcvd: 114

┌──(kali㉿up2291275)-[~]
└─$
```

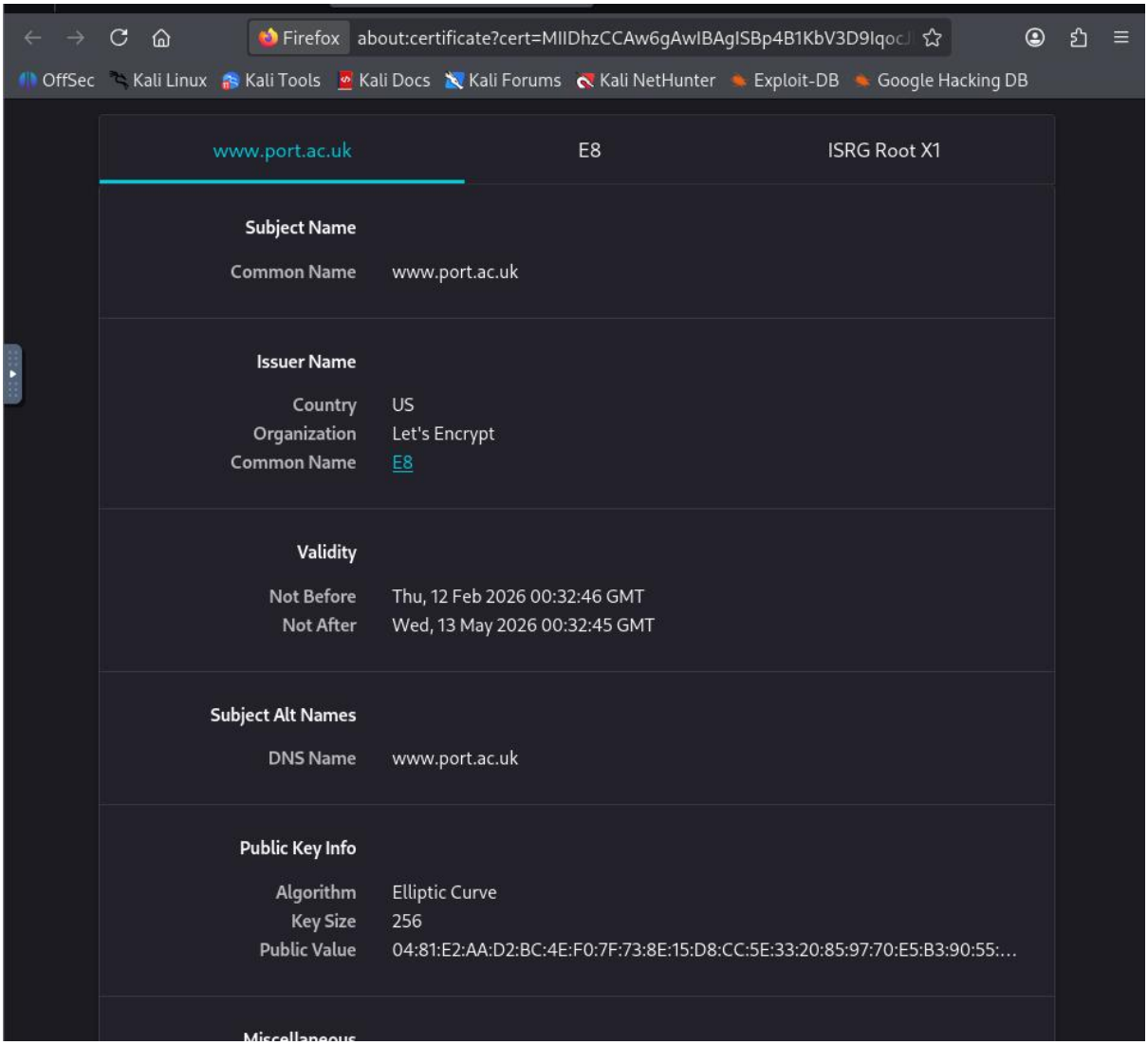
DNS Root Server

Reflection

In this lab, you used nslookup, dig, and host to obtain information from DNS zone files. Which tool would you use to begin a passive reconnaissance effort against a targeted domain? Why?

I would choose Dig because it offers a clearer and more detailed view of the information I need while remaining passive. Overall, it provides more comprehensive results compared to both nslookup and host.

Q3.1: What domain was the certificate issued to? What organization issued it? View the certificate. When will it expire? What is the certificate signature encryption algorithm



Q3.2: Who do you think these subdomains are intended to be used by? Explain.

Other subdomains are likely for internal BBC staff for internal work such as site maintenance.

What other domain is associated with the BBC domain according to the crt.sh information?

Amazon is the other associated domain.

Q3.3: Reflection Question

Compare the output of the tools used in this task. Which tool seems to give the most useful information?

In Kali, sslscan is far more user-friendly than crt.sh because it uses colour-coding that makes the information easier to interpret. It also provides more comprehensive details, including insights into specific vulnerabilities and whether the target domain is susceptible to them.

Q4.1: What does the -d option do?

```
-d, --domain DOMAIN   Domain to search.
```

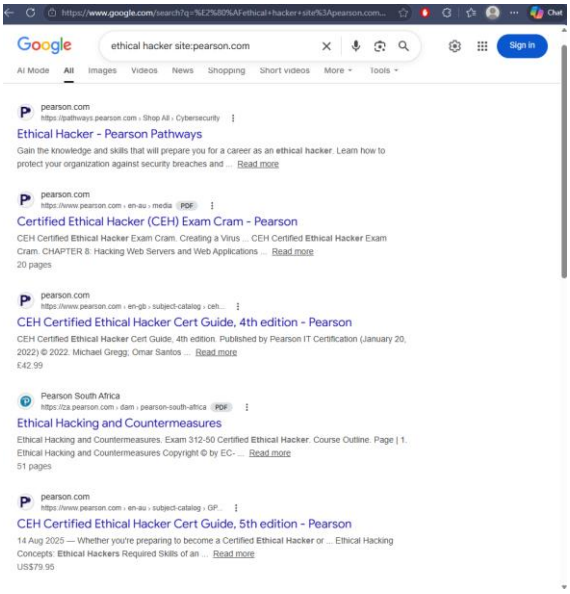
Q4.2: Reflection

You have used several tools to locate email addresses and follow leads to learn more about data breaches, company information, and personal information about target personnel. You have also inspected file metadata in an effort to learn more information about the file, the file owners, and device-specific information.

How would you describe this process? Did you discover huge amounts of information? What does this say about the corporate and personnel reconnaissance process?

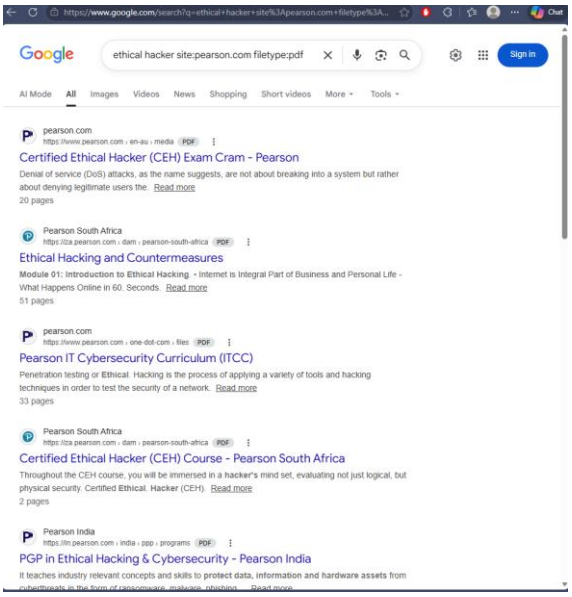
This process is essential but often time-consuming. Scanning a site for vulnerable email addresses can reveal significant security weaknesses, including exposed employee accounts or sensitive files whose metadata may disclose further information. Overall, this demonstrates that corporate and personnel reconnaissance, while lengthy, is highly valuable. It can uncover prior leaks and vulnerabilities that provide clear entry points into a system.

Q5.1: What do all the results have in common?



Only Pearson sites have loaded.

Q5.2: What file type is opened by each of the results?

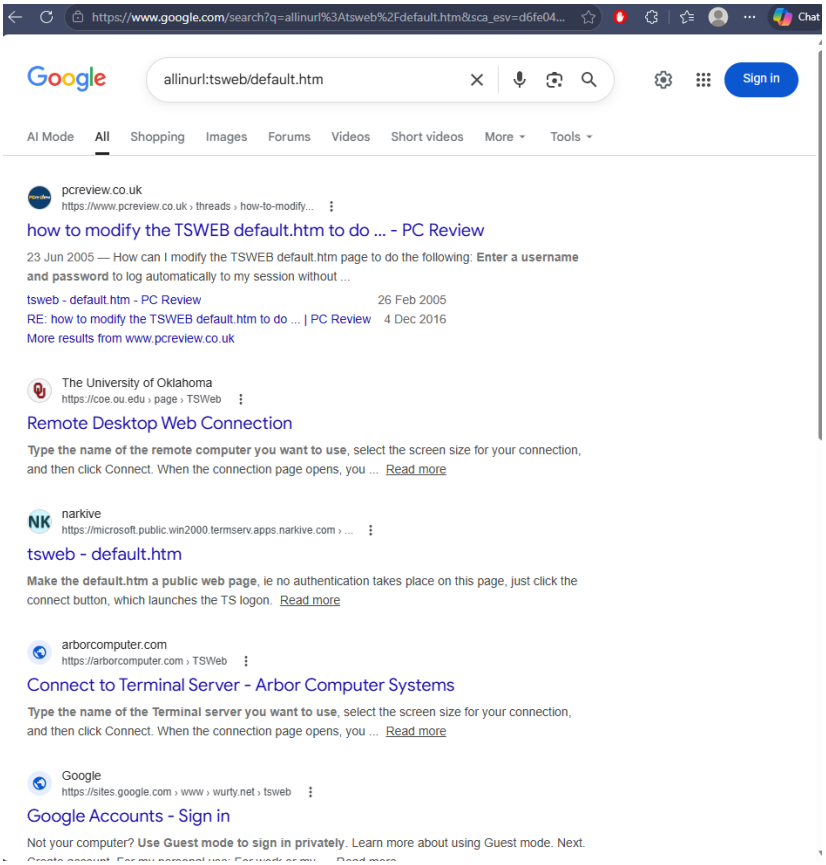


Only PDF Files have loaded

Q5.3: What type of information could a hacker gain from this type of dork?

An attacker could use this dork to identify certain employees with key roles, within a company, and gain more information about them, which can be used to help aid a social engineering attack.

Q5.4: What does this Dork return?



Provides links of desktop login portals

Q5.5: How can it be advantageous for a hacker to collect information from an archived site?

Old and archived websites may hold information that may be more sensitive now compared to prior times of when they were not, therefore not held on current websites.

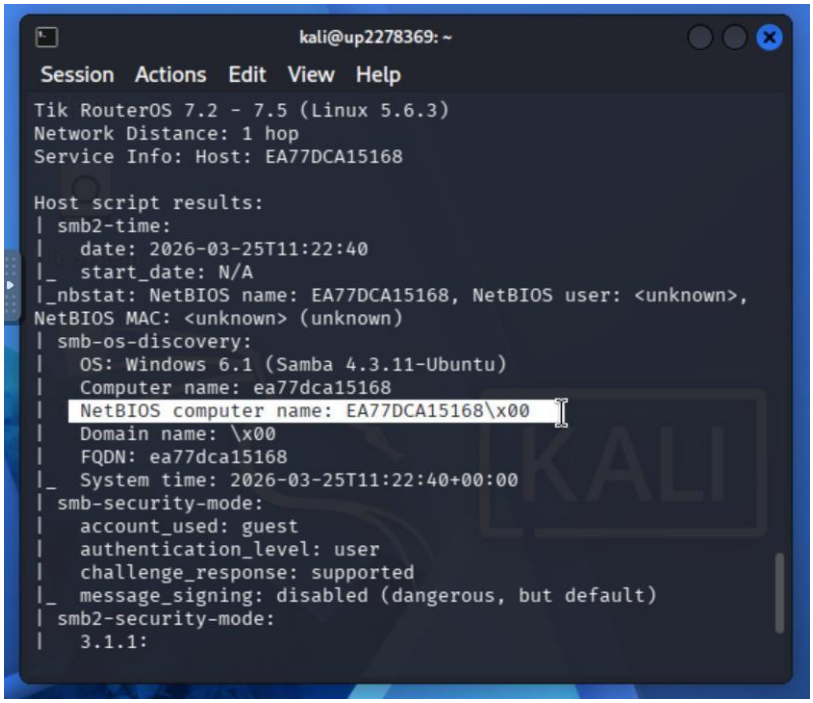
Q5.6: Reflection Question

Why is passive reconnaissance so important for effective hacking and penetration texting?

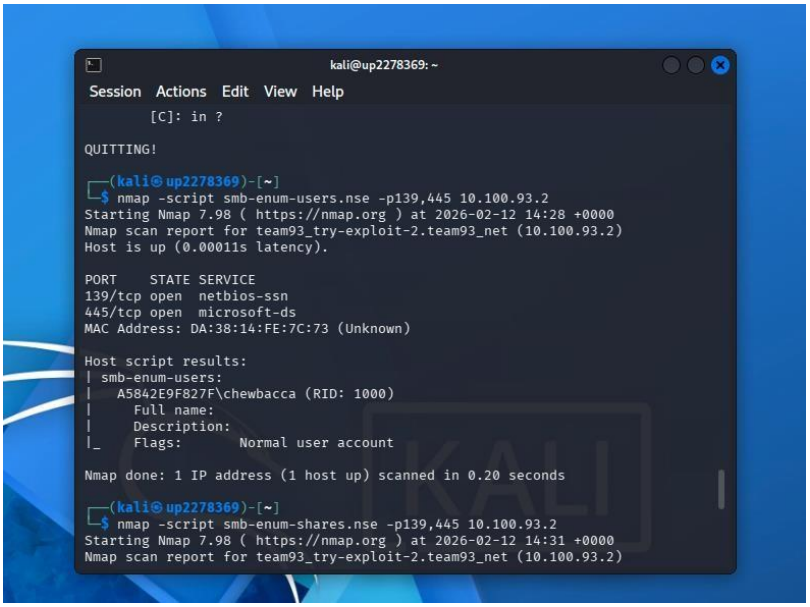
Passive reconnaissance enables a penetration tester to quietly observe a system and gather information or identify vulnerabilities that could later support deeper access without alerting the target.

Lab3:

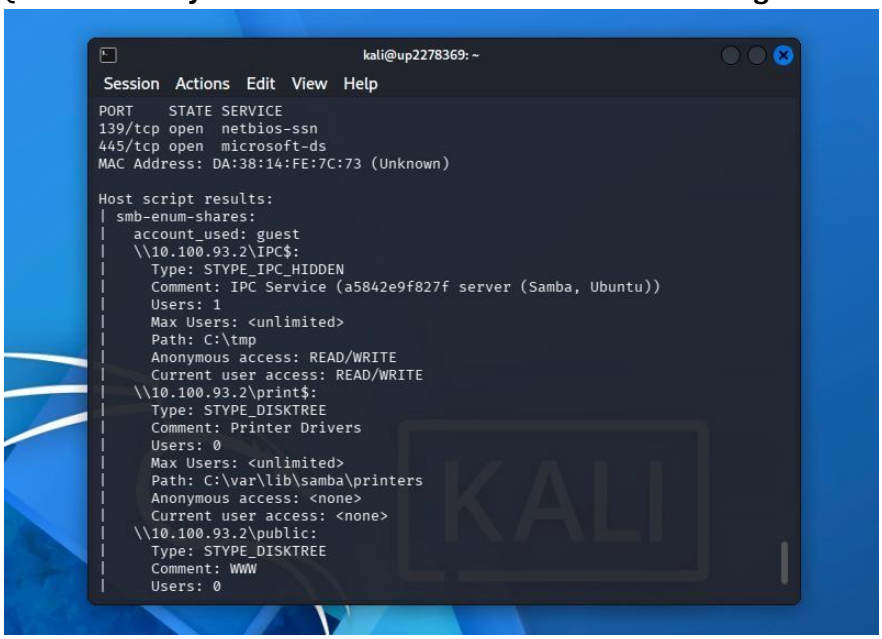
Q1.1 **What is the NetBIOS computer name assigned to the target host?**



Q1.2 **Did the script uncover any SMB usernames on the target host? If so, how many? What are they?**

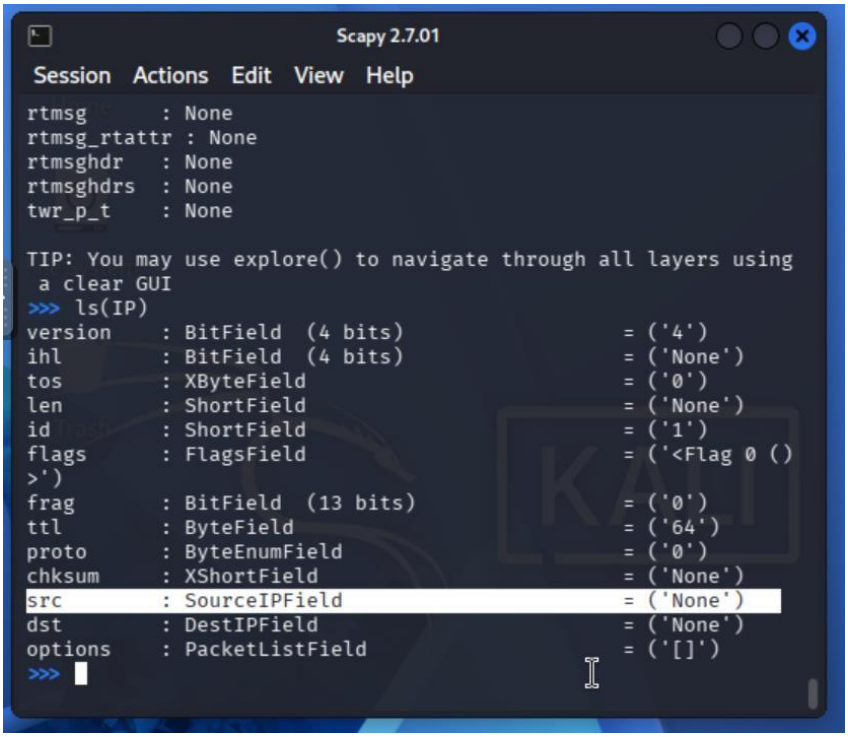


Q1.3 **How many hidden shares were discovered on the target host?**



Q1.4-Reflection

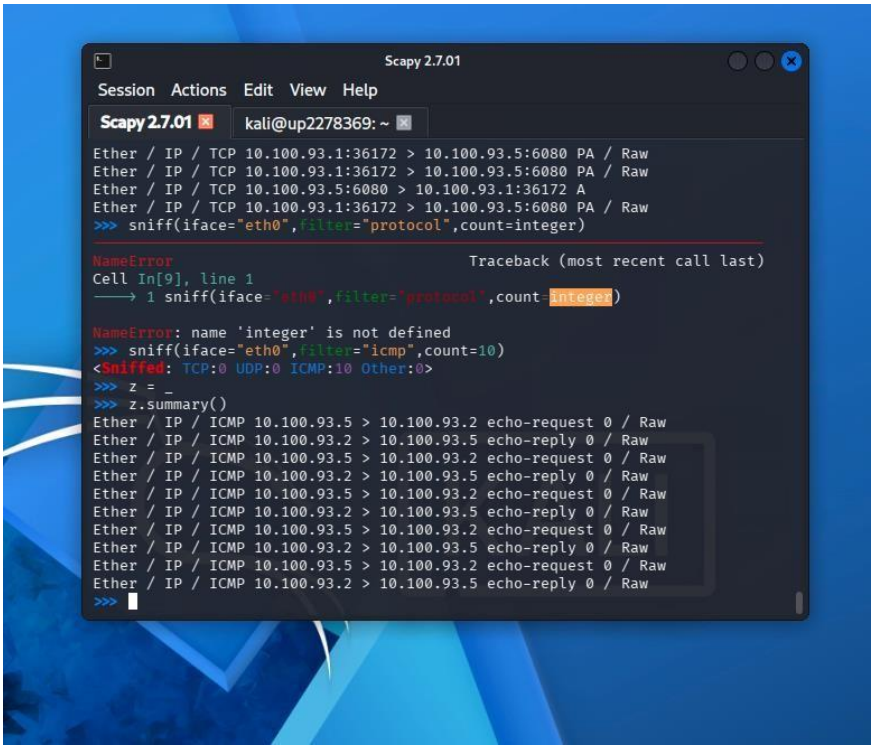
Q2.1 **Which field do you think you would change to create a packet that would generate a reply to a target machine, rather than the machine that actually sent the packet?** src (Sourcefield)



Q2.2 **What traffic is displayed in the output of the nsummary() function?**

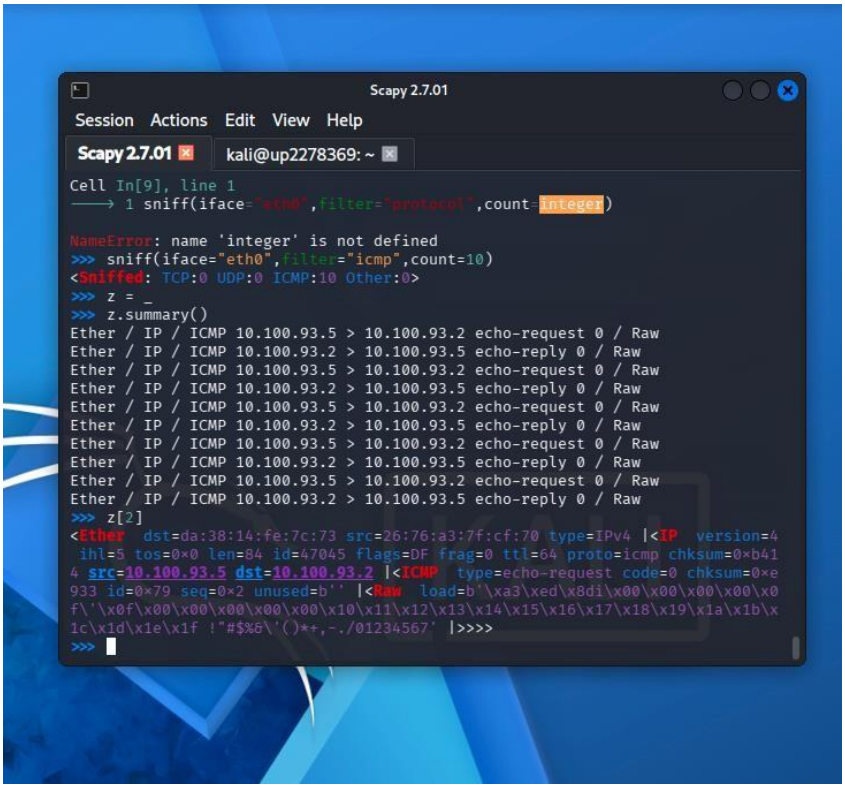
through ports that most likely don't need to be open; the ports should be closed to remedy this.

The output summary shows myriad request and reply packets



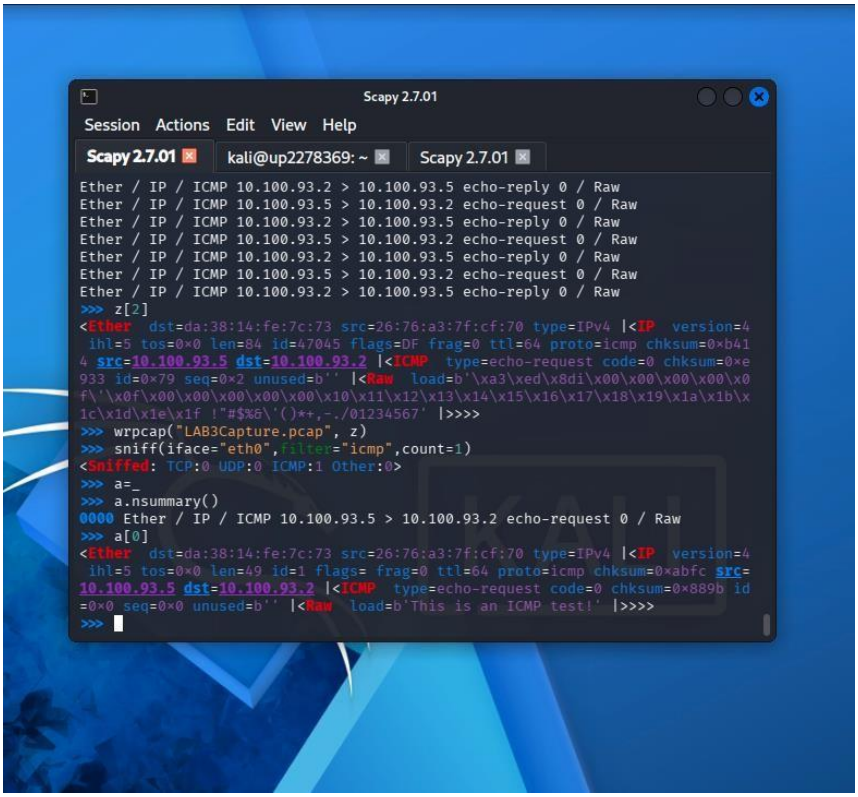
Q2.3 **Why are there two sets of source and destination fields?**

There are two source and destination fields as one is for the IP address whilst the other is for the MAC address of the source and destination device.



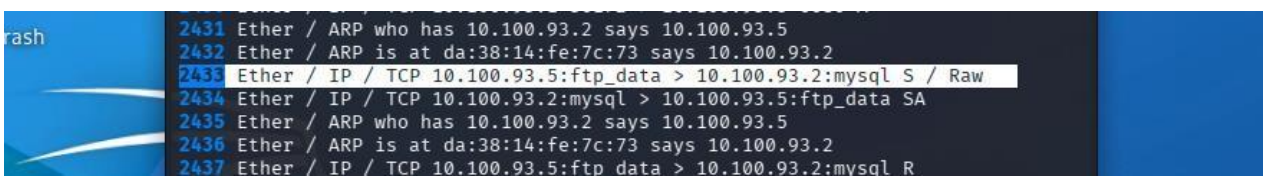
Q2.4 **What is different between the original ICMP packet conversation and the custom ICMP packet conversation?**

The custom load is the chosen message we entered into the packet, whereas on the other packet it is seemingly just random data. The id of the custom packet is 1, whereas the id of the first packet is 47045. The chksum on both packets are also differing.



Q2.5 **What does the SA flag indicate in the packet returned from 10.100.93.5?**

The returned SA is a SYN-ACK flag



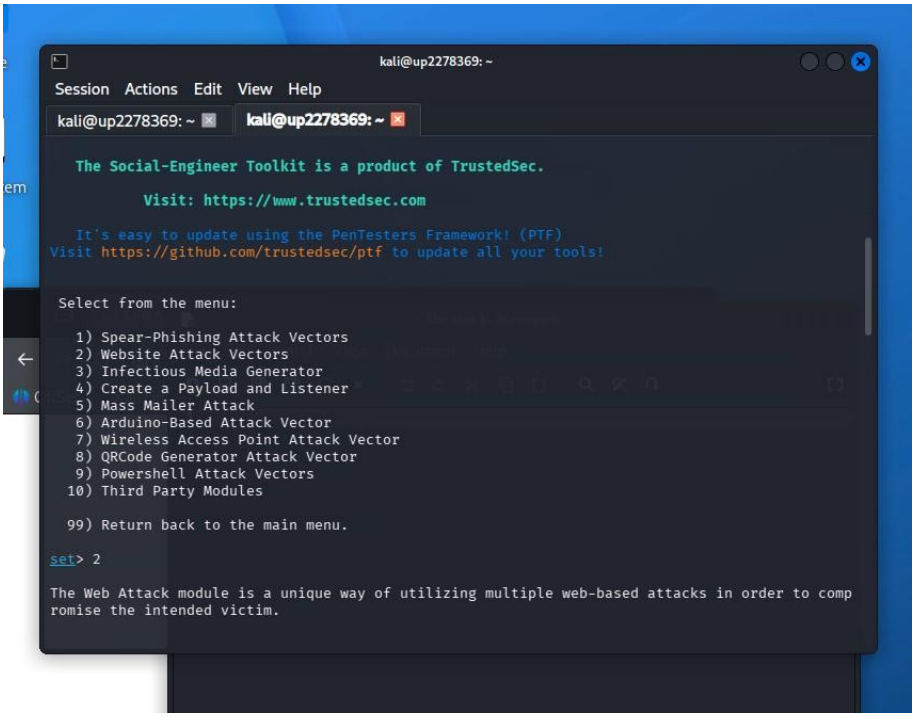
Q2.6-Reflection

1) How could spoofing the source address of an ICMP echorequest be used to launch a denial-of-service attack against a target host?	By spoofing the source address, the victim of the attack has no idea where the actual attack is coming from and thus can't accurately shut it down within a reasonable timeframe.

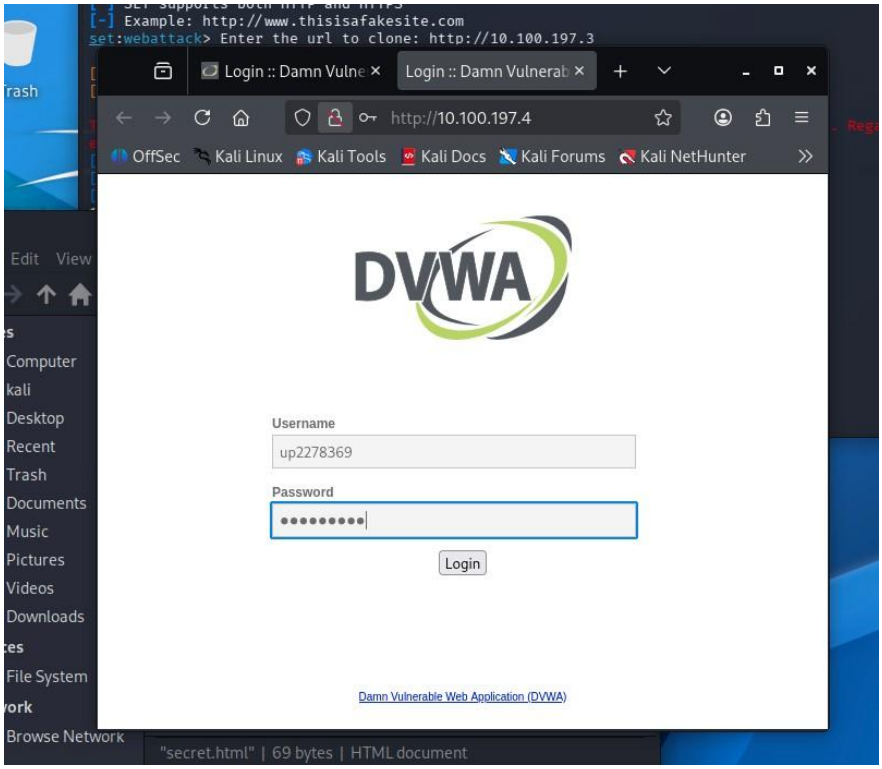
Lab4:

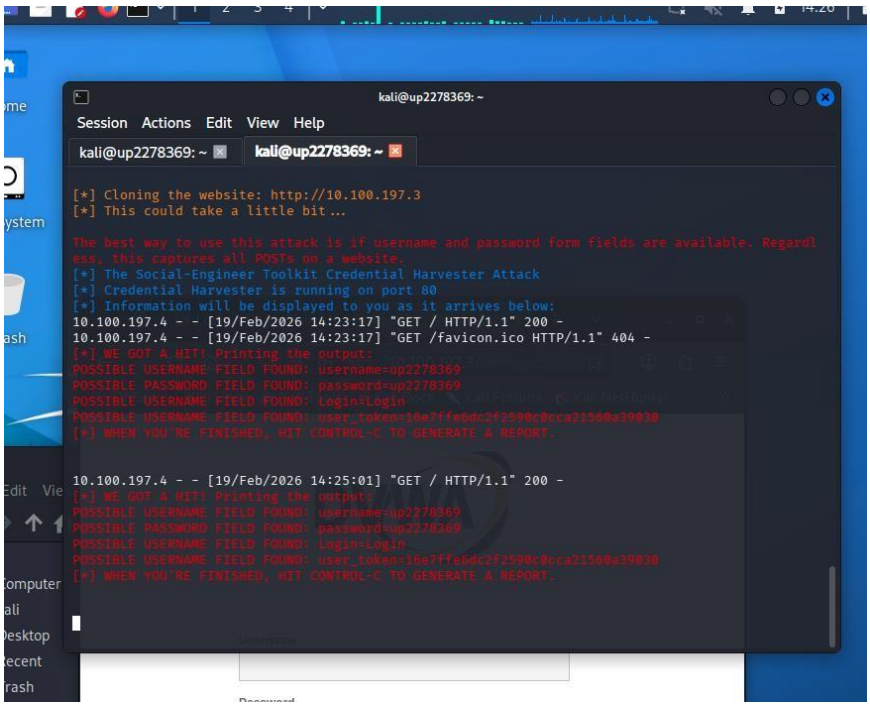
Q1.1 **Which option generates a reverse TCP payload that opens a reverse shell on the victim machine and connects back to the attacker?**

4) Create a Payload and Listener



Q1.2 Enter your cyber range username as the username and your University ID as the password on the cloned login page.

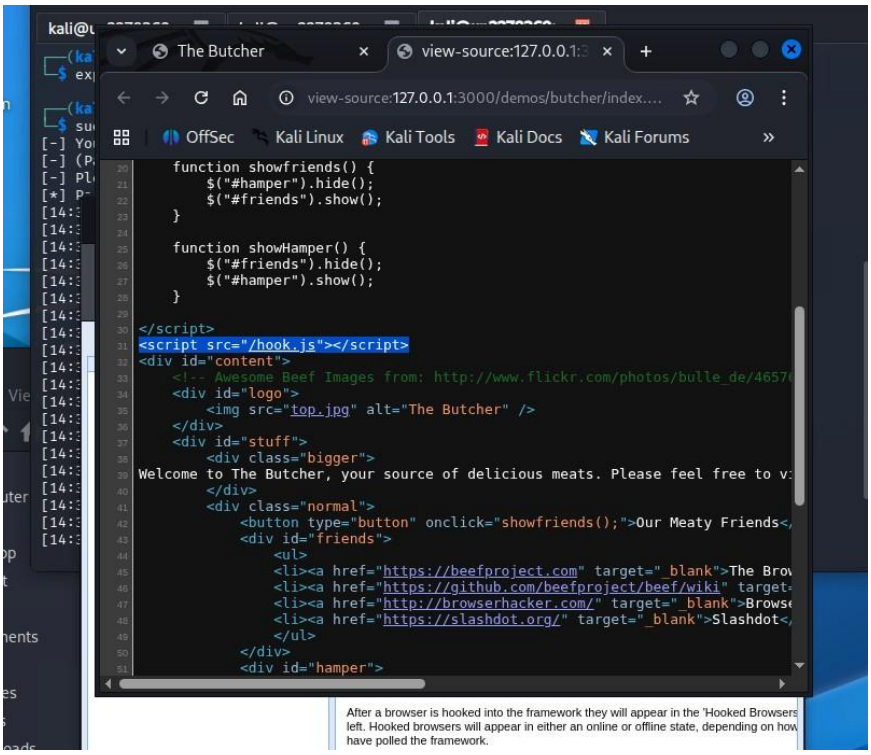




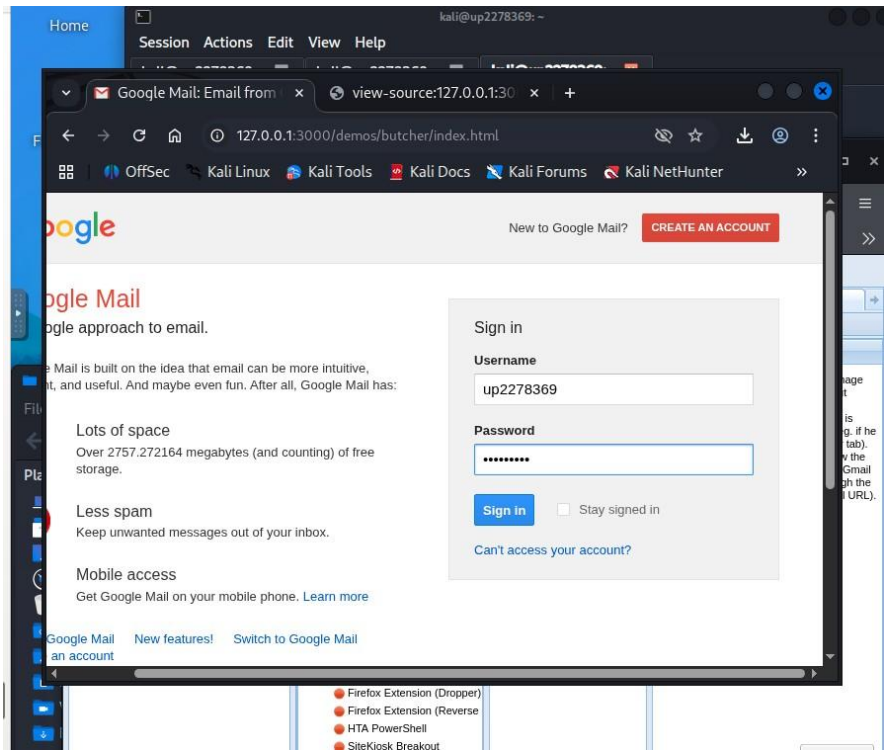
Q1.3 - Reflection

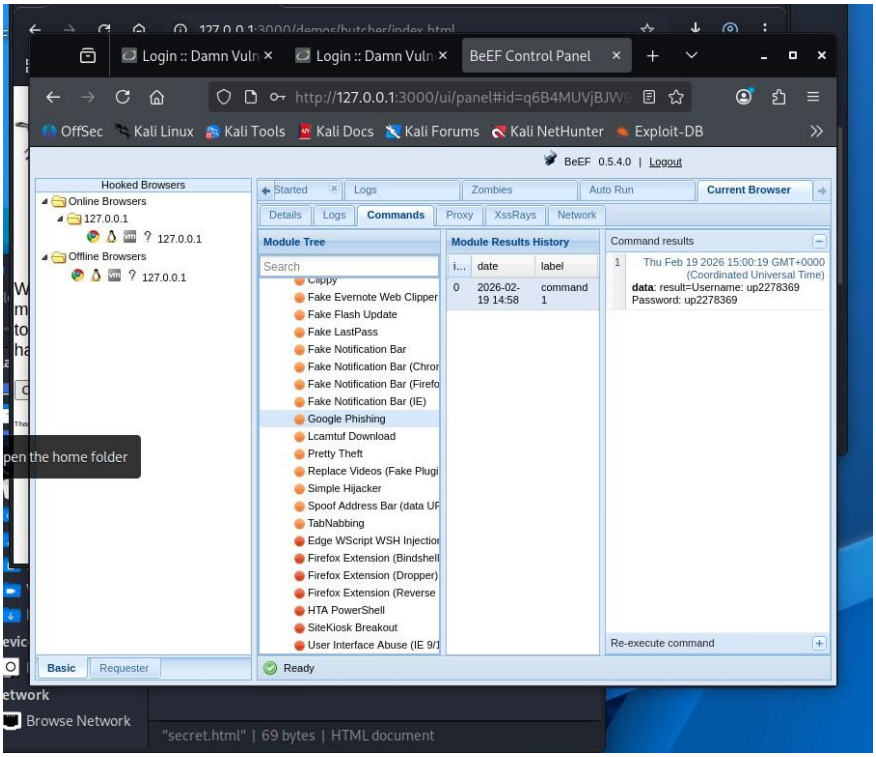
1) How could an ethical hacker use this procedure in a test?	An ethical Hacker could use this procedure and send a phishing email, with a link to this fake login page, to
	several employees at a company to see how many of them give up their credentials without raising suspicions.

Q2.1 **Which line(s) in the page's HTML source load and execute the JavaScript that creates the BeEF "hook"? Take a screenshot with these lines highlighted.**

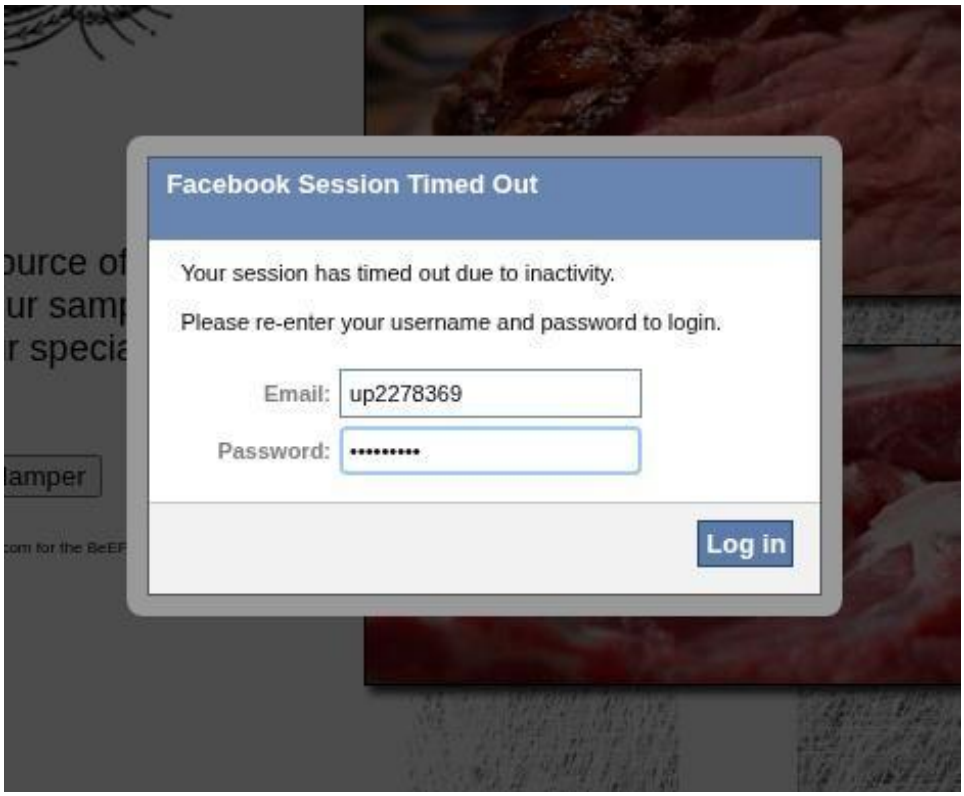


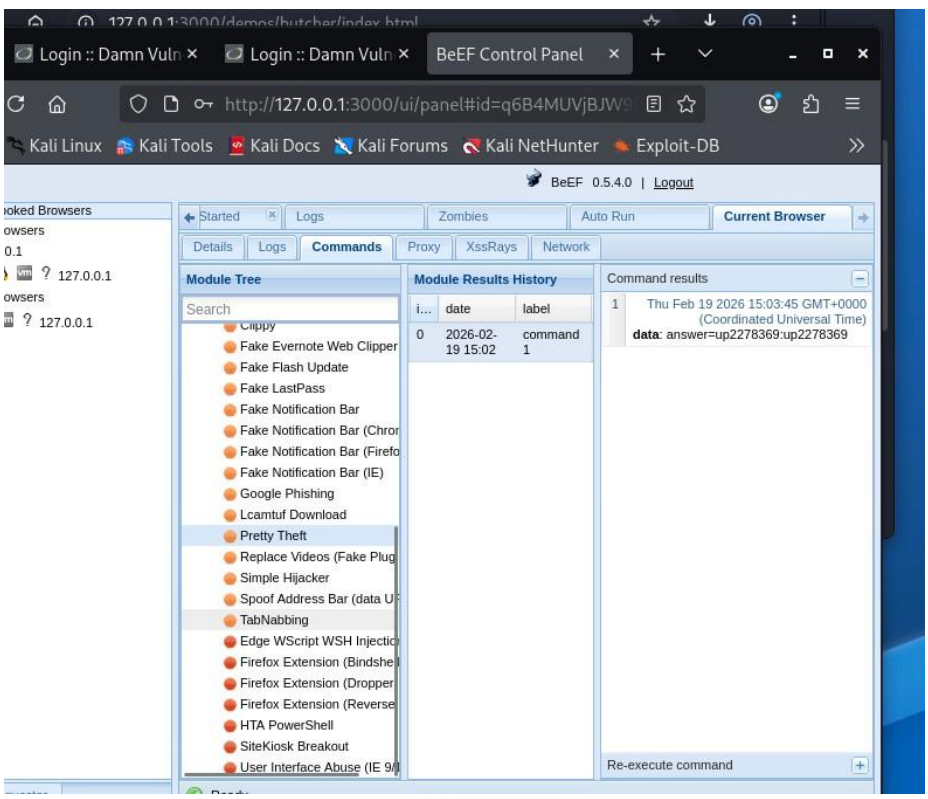
Q2.2 **Enter your cyber range username in Username and your University ID in Password, then take a screenshot and include it in your answer.**





Q2.3 **Enter your cyber range username in Username and your University ID in Password, then take a screenshot and include it in your answer.**



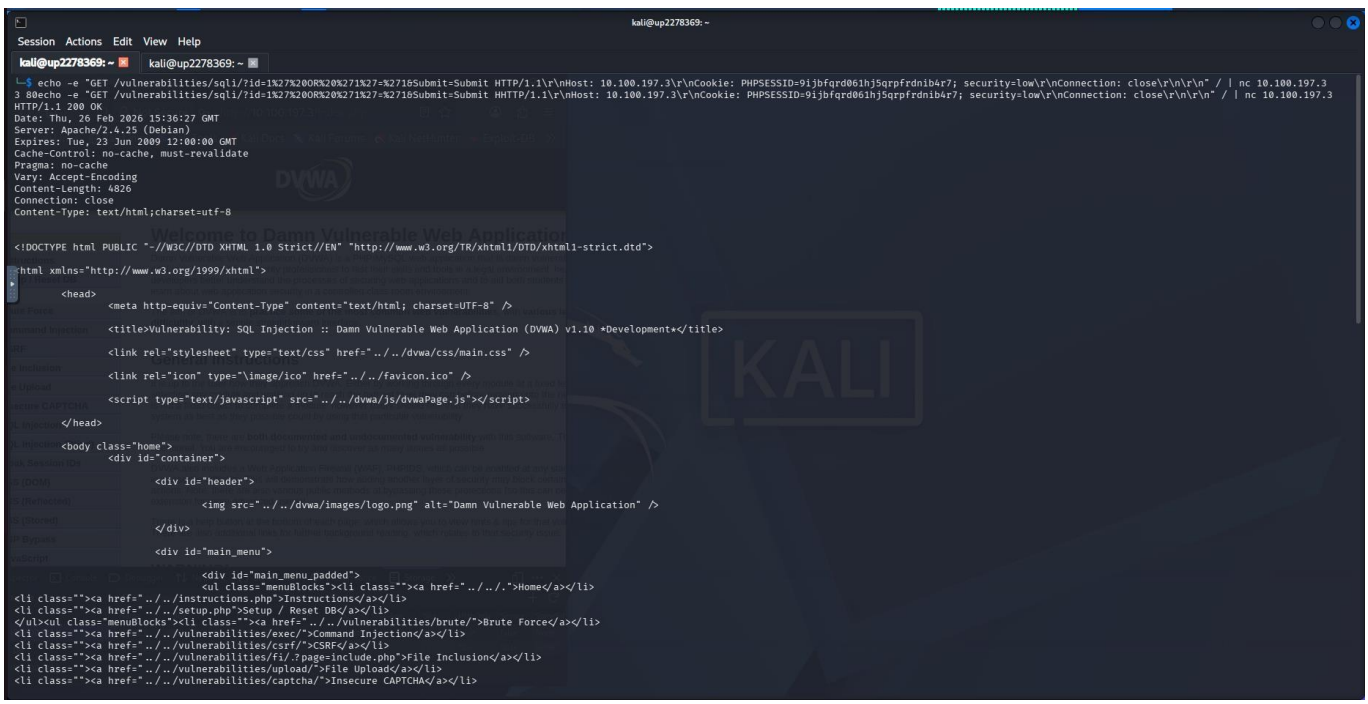


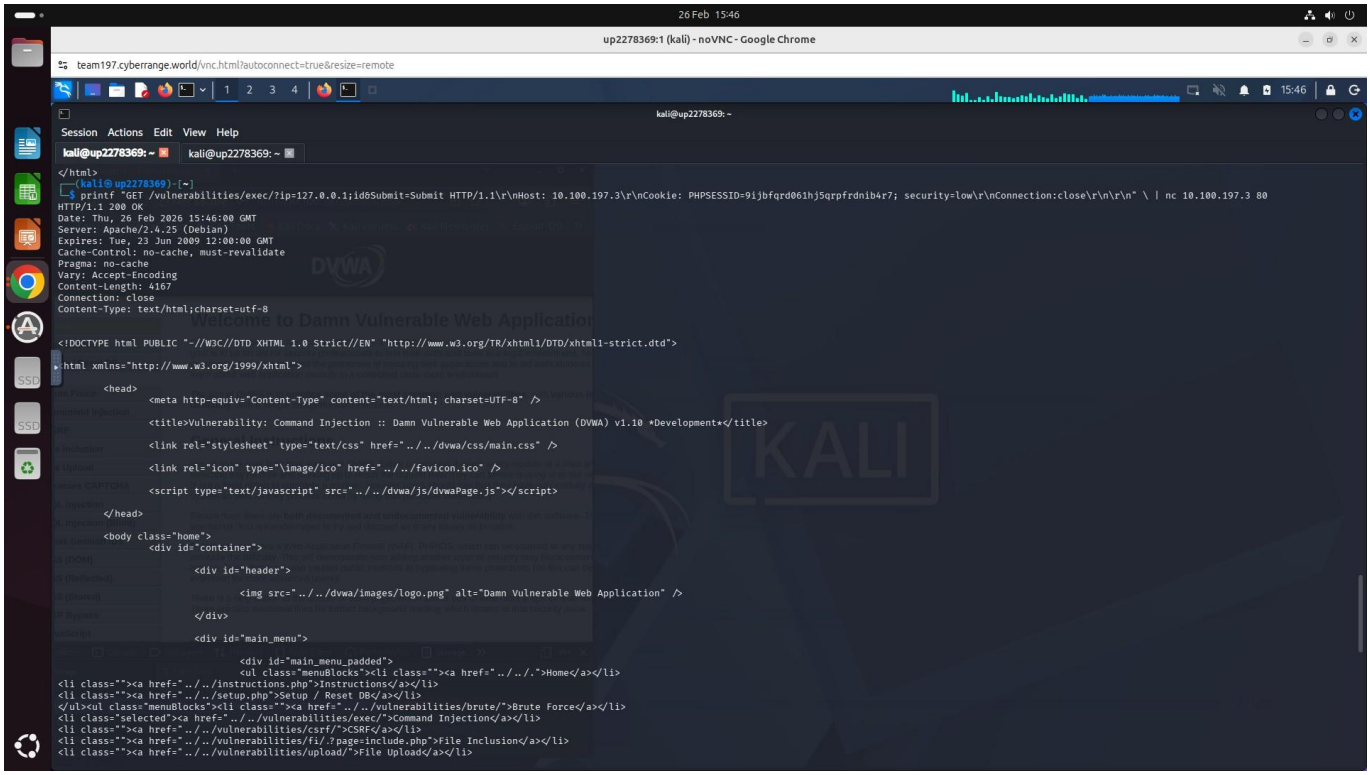
Q2.4-Reflection

1) In an earlier lab, you were introduced to the Social Engineer Toolkit (SET). How might the SET and BeEF be used in combination to perform a social engineering penetration test?	A penetration tester can use BeEF to redirect one or more employees to the spoofed webpage made using the SET and encourage them to enter their details and examine how many provide them so willingly, moreover they can then use these stolen details for unauthorized access to the company's systems.

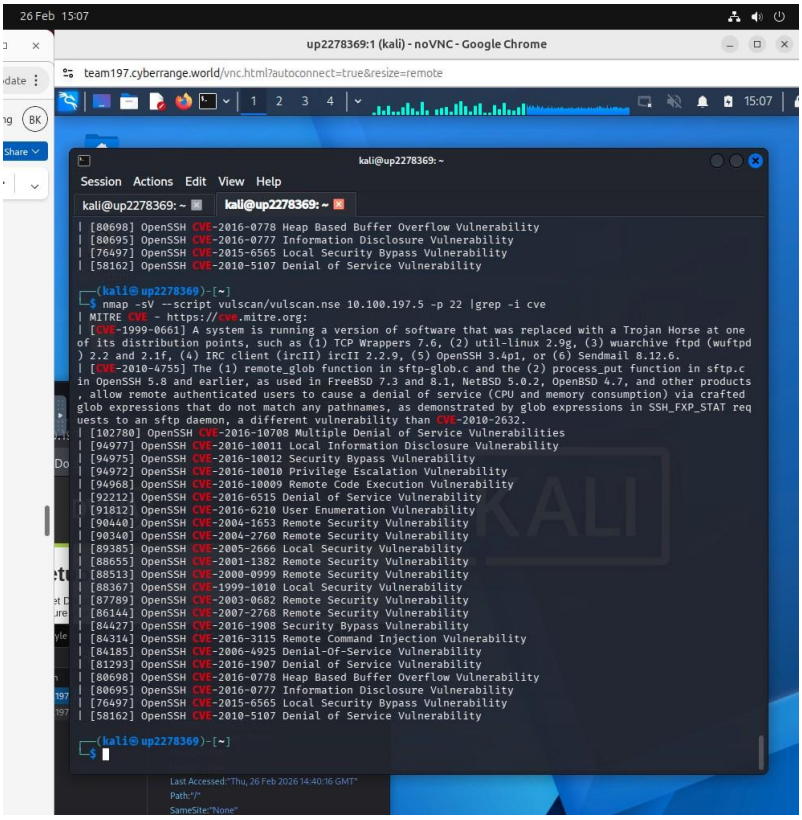
Lab5:

Q1.1 **Run the nc commands in (c (sql injection) and d (command injection)) and provide the screenshots as your answer. Make sure that your cyber range ID is shown in terminal's prompt.**

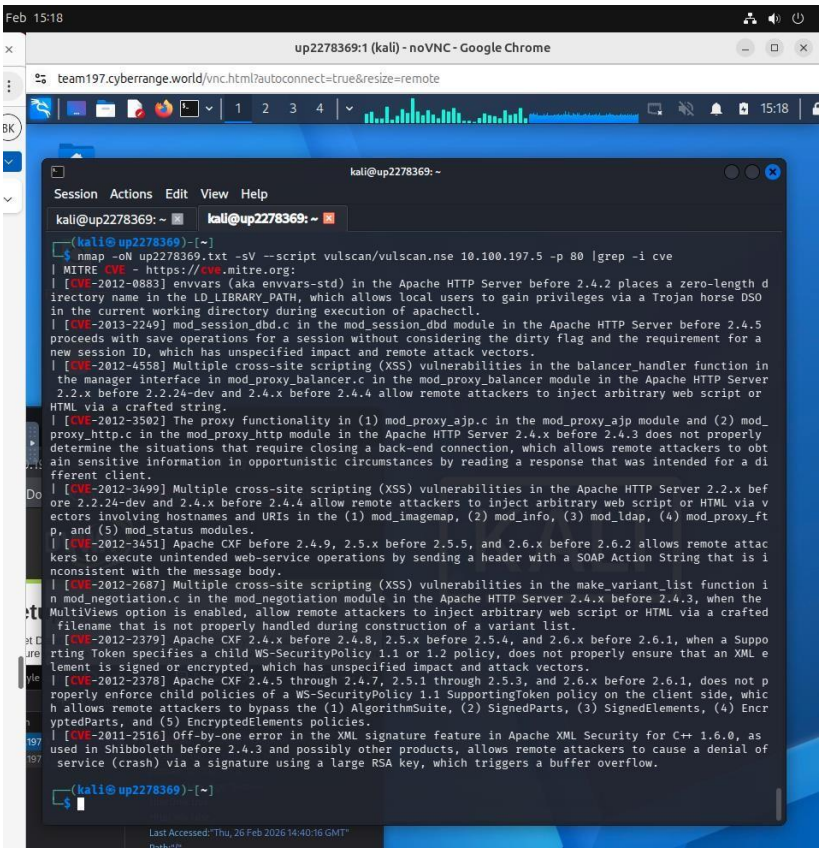


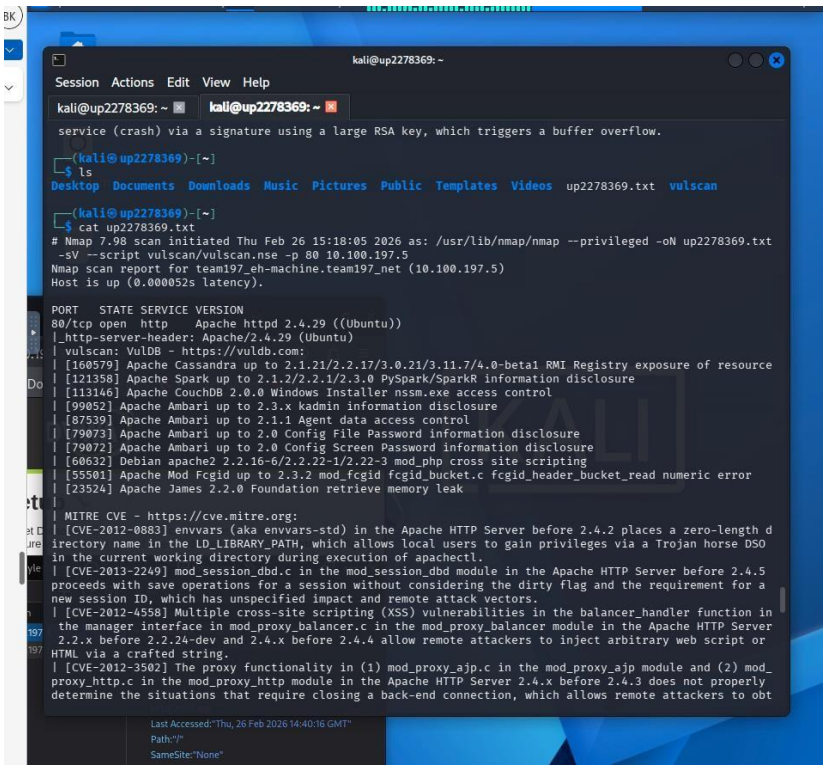


Q2.1 **repeat the same scan (in d) using the other open port on that machine. Show screenshot only.**



Q2.2 **Use the -oN option to save Nmap output in text file. Use your-cyber-range-id.txt as the file name (for example testbander.txt). Provide the screenshots (in f) showing the command used, the file created and file contents.**





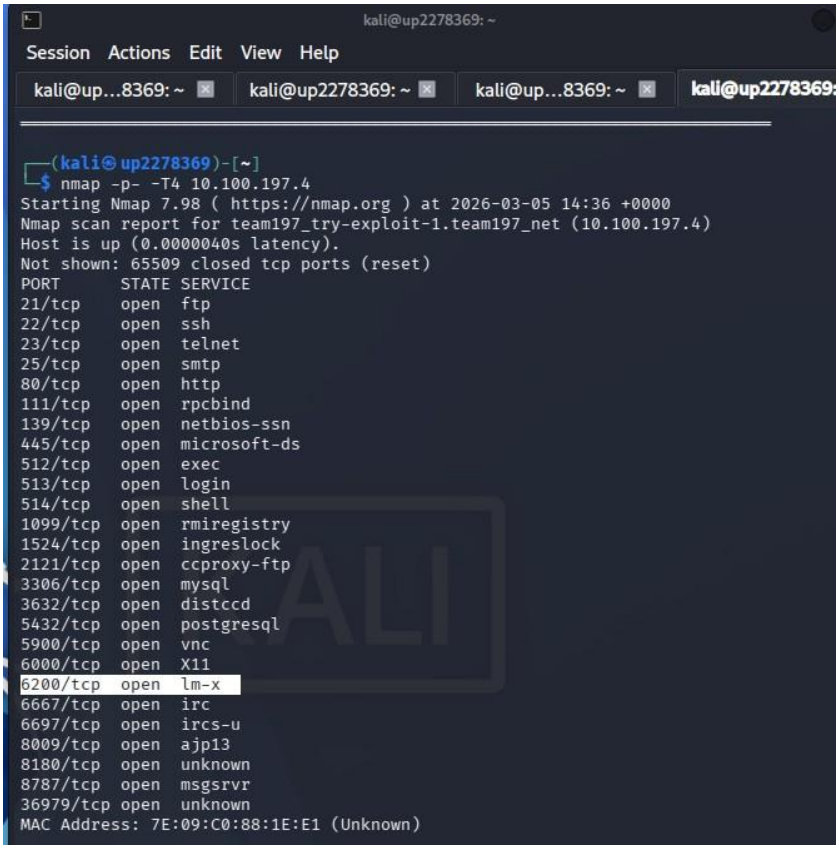
Q3.1-Reflection

1) Based on the vulnerabilityscanning techniques used in this lab, and vulnerability mapping explain how the information gathered from these tools can be correlated to assess exploit feasibility. In your answer, discuss how service versions, misconfigurations, and exposed interfaces influence the accuracy of vulnerability detection and the prioritisation of potential attack paths.	Firstly, exposed interfaces provide an easy inlet for an attacker to access, often opening other avenues of attack as well that are likely easier to exploit than other areas. Secondly, an outdated service version can prove dangerous to security as such things are usually updated to remove known exploits and bugs, so an older version of software likely has openly known exploits that attackers can easily leverage. Often once an outdated service version with a known and easy to follow exploit is discovered, it is often a high priority attack target as such a thing is easy to exploit yet yields a lot of access/information for the attacker. Finally, any misconfiguration can be taken advantage of by an attacker. An example would be a given user having more privileges than they need to fulfill their role in a company, such users, for example a CEO with complete system access, are usually high priority targets of phishing and other attacks as if their accounts are broken into, they can provide a lot of information and control. Another example of misconfiguration would be poor or no input

	sanitization which would open the company to being vulnerable to SQL injection attacks as well.

Lab6:

Q1. **When you reach this point, take a screenshot of the nmap output and put it in the portfolio. Make sure your Cyber Range's username is shown in the screenshot.**



Q2 **Spawn an interactive shell session (as shown above) and run ifconfig. Take a screenshot that shows your 'Try Exploit 1' machine as an answer to the question.**

```
kali@up2278369: ~
Session  Actions  Edit  View  Help
kali@up2278369: ~   kali@up2278369: ~   kali@up2278369: ~   kali@up2278369: ~   kali@up2278369: ~

          RX packets:379 errors:0 dropped:0 overruns:0 frame:0
          TX packets:385 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:65935 (64.3 KB)  TX bytes:67856 (66.2 KB)

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:65536  Metric:1
          RX packets:203 errors:0 dropped:0 overruns:0 frame:0
          TX packets:203 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:74926 (73.1 KB)  TX bytes:74926 (73.1 KB)

python -c 'import pty; pty.spawn("/bin/bash")'
msfadmin@9b8632d5ccb6:~$ sudo su -
sudo su -
[sudo] password for msfadmin: msfadmin

root@9b8632d5ccb6:~# id
id
uid=0(root) gid=0(root) groups=0(root)
root@9b8632d5ccb6:~# uname -a
uname -a
Linux 9b8632d5ccb6 6.8.0-88-generic #89~Ubuntu SMP PREEMPT_DYNAMIC Sat Oct 11 01:02:46 UTC 2025 x86_64 GNU/Linux
root@9b8632d5ccb6:~# ifconfig
ifconfig
eth0      Link encap:Ethernet  HWaddr 2a:45:ab:65:33:bf
          inet addr:10.100.197.4  Bcast:10.100.197.255  Mask:255.255.255.0
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:418 errors:0 dropped:0 overruns:0 frame:0
          TX packets:417 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:69220 (67.5 KB)  TX bytes:72686 (70.9 KB)

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:65536  Metric:1
          RX packets:211 errors:0 dropped:0 overruns:0 frame:0
          TX packets:211 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:79014 (77.1 KB)  TX bytes:79014 (77.1 KB)

root@9b8632d5ccb6:~#
```

Q3 **Take a screenshot of the command outputs above and include and put it in the portfolio.**

```
┌──(kali㉿up2278369)-[~]
└─$ smbclient //10.100.197.4/tmp -N
Anonymous login successful
Try "help" to get a list of possible commands.
smb: \> ls
  .                                   D        0  Thu Mar  5 15:41:52 2026
  ..                                 DR        0  Thu Mar  5 14:01:01 2026
  .X11-unix                          DH        0  Thu Mar  5 14:01:06 2026
  .X0-lock                           HR       11  Thu Mar  5 14:01:06 2026
  .ICE-unix                          DH        0  Sun Jan 28 03:08:08 2018
  720.jsvc_up                         R        0  Thu Mar  5 14:01:11 2026
  826.jsvc_up                         R        0  Sun Jan 28 07:08:40 2018
  810.jsvc_up                         R        0  Sun Jan 28 03:54:31 2018
  1582.jsvc_up                        R        0  Sun Jan 28 04:01:49 2018
  1823.jsvc_up                        R        0  Sun Jan 28 02:57:44 2018

                1801927152 blocks of size 1024. 1067434932 blocks available
smb: \> put /etc/hostname up2278369.txt
putting file /etc/hostname as \up2278369.txt (9.8 kB/s) (average 9.8 kB/s)
smb: \> ls
  .                                   D        0  Thu Mar  5 15:42:37 2026
  ..                                 DR        0  Thu Mar  5 14:01:01 2026
  .X11-unix                          DH        0  Thu Mar  5 14:01:06 2026
  .X0-lock                           HR       11  Thu Mar  5 14:01:06 2026
  .ICE-unix                          DH        0  Sun Jan 28 03:08:08 2018
  720.jsvc_up                         R        0  Thu Mar  5 14:01:11 2026
  up2278369.txt                       A       10  Thu Mar  5 15:42:37 2026
  826.jsvc_up                         R        0  Sun Jan 28 07:08:40 2018
  810.jsvc_up                         R        0  Sun Jan 28 03:54:31 2018
  1582.jsvc_up                        R        0  Sun Jan 28 04:01:49 2018
  1823.jsvc_up                        R        0  Sun Jan 28 02:57:44 2018

                1801927152 blocks of size 1024. 1067431136 blocks available
smb: \> exit
```

Q4 **Take a screenshot of the command output above and add it to the portfolio. Make sure to show the terminal prompt that shows your cyber range username and a couple of lines from the output.**

```
┌──(kali㉿up2278369)-[~]
└─$ snmp-check 10.100.197.3 -c public
snmp-check v1.9 - SNMP enumerator
Copyright (c) 2005-2015 by Matteo Cantoni (www.nothink.org)

[+] Try to connect to 10.100.197.3:161 using SNMPv1 and community 'public'

[*] System information:

  Host IP address               : 10.100.197.3
  Hostname                      : vulnbox-alpha
  Description                   : Linux dfea5460d026 6.8.0-88-generic #89-Ubuntu SMP PREEMPT_DYNAMIC Sat Oct 11 01:02:46
UTC 2025 x86_64
  Contact                       : "sysadmin@corp.internal (IT Department)"
  Location                      : "Server Room B, Floor 2, HQ Building"
  Uptime snmp                   : 87 days, 01:39:00.06
  Uptime system                 : 01:57:09.18
  System date                   : 2026-3-5 15:58:04.0

[*] Network information:

  IP forwarding enabled         : yes
  Default TTL                   : 64
  TCP segments received         : 3265
  TCP segments sent             : 3342
  TCP segments retrans          : 0
  Input datagrams               : 3466
  Delivered datagrams           : 3466
  Output datagrams              : 3448

[*] Network interfaces:

  Interface                     : [ up ] lo
  Id                            : 1
  Mac Address                   : :::::
  Type                          : softwareLoopback
  Speed                         : 10 Mbps
  MTU                           : 65536
  In octets                     : 2160
  Out octets                    : 2160

  Interface                     : [ up ] eth0
  Id                            : 2
  Mac Address                   : a6:af:9b:97:5f:dd
```

Q5-Reflection

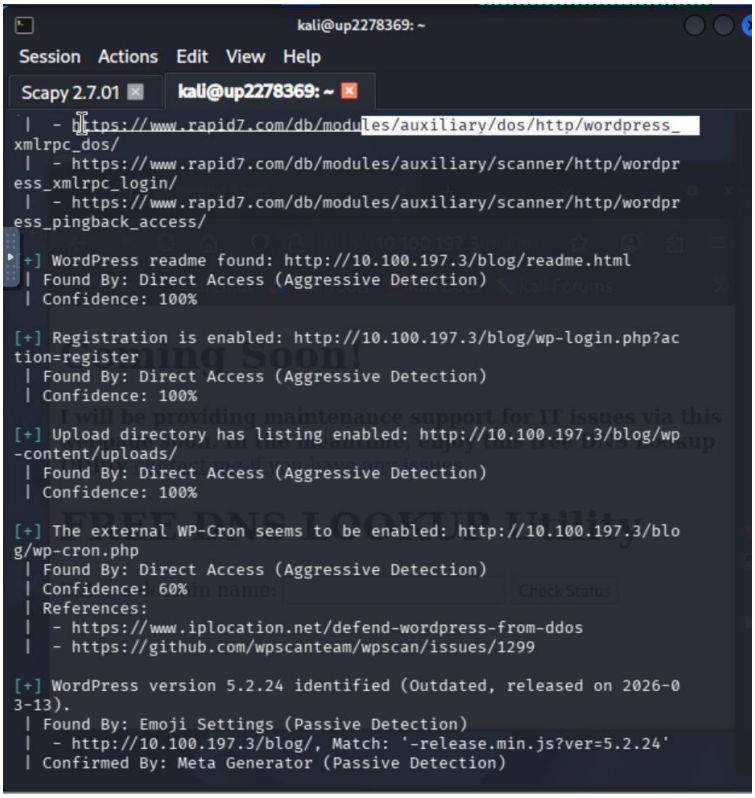
1) After doing all the tasks, which service (FTP, SSH, SMB, SMTP, SNMP) would you secure first on a real system, and why?	I would secure SNMP first on a system due to two factors: 1) The information leakage that it can provide can lead to several different avenues of attack being exposed with the full system configuration being laid out to the attacker 2) It would be a relatively easy fix of just changing the default passwords for the community strings.

Lab7:

Q1 **What pages does the website have? Which page(s) are WordPress?**

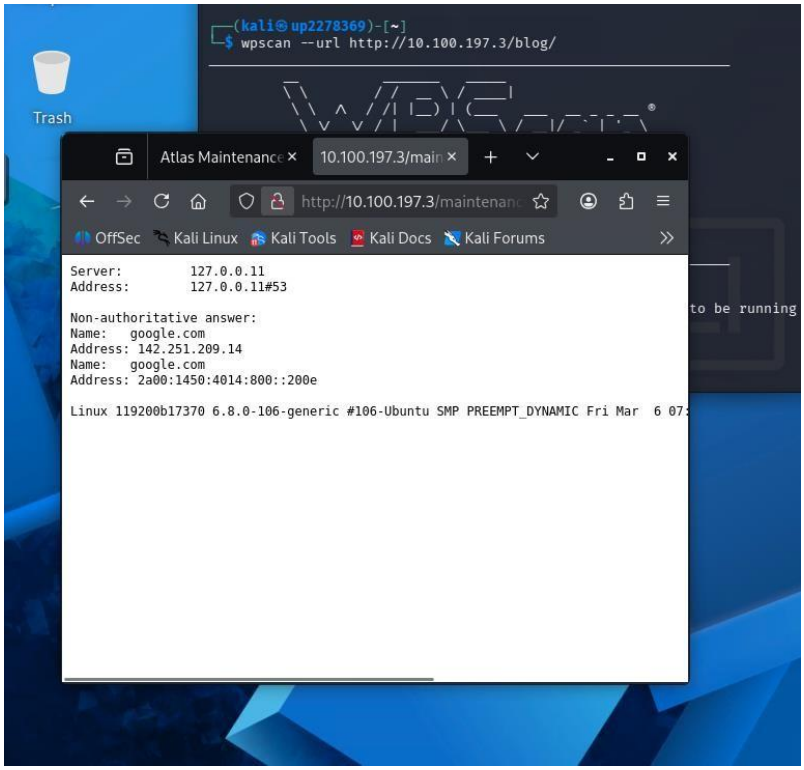
```
Session  Actions  Edit  View  Help
Scapy 2.7.01   kali@up2278369: ~
└─$ dirb http://10.100.197.3

_____________
DIRB v2.22
By The Dark Raver
_____________

START_TIME: Wed Mar 25 13:24:06 2026
URL_BASE: http://10.100.197.3/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

_____________

GENERATED WORDS: 4612
---- Scanning URL: http://10.100.197.3/ ----
==> DIRECTORY: http://10.100.197.3/blog/
+ http://10.100.197.3/index.html (CODE:200|SIZE:10918)
+ http://10.100.197.3/info.php (CODE:200|SIZE:12)

==> DIRECTORY: http://10.100.197.3/javascript/
==> DIRECTORY: http://10.100.197.3/maintenance/

==> DIRECTORY: http://10.100.197.3/phpmyadmin/
+ http://10.100.197.3/server-status (CODE:403|SIZE:277)

---- Entering directory: http://10.100.197.3/blog/ ----

+ http://10.100.197.3/blog/index.php (CODE:301|SIZE:0)
```

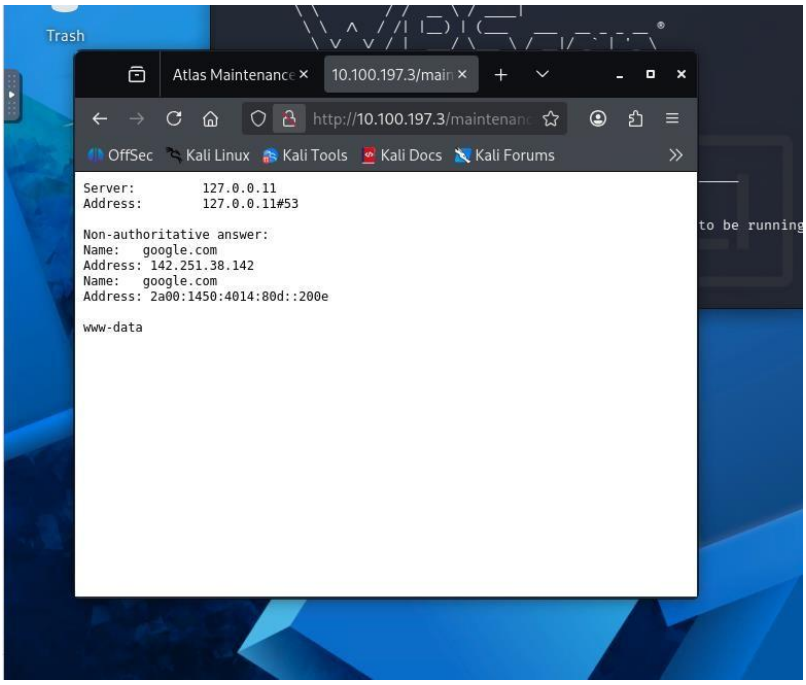
```
kali@up2278369: ~
Session  Actions  Edit  View  Help
Scapy 2.7.01   kali@up2278369: ~
_______________________________________________________________
         __          _______   _____
         \ \        / /  __ \ / ____|
          \ \  /\  / /| |__) | (___   ___  __ _ _ __ ®
           \ \/  \/ / |  ___/ \___ \ / __|/ _` | '_ \
            \  /\  /  | |     ____) | (__| (_| | | | |
             \/  \/   |_|    |_____/ \___|\__,_|_| |_|

        WordPress Security Scanner by the WPScan Team
                         Version 3.8.28
      Sponsored by Automattic - https://automattic.com/
      @_WPScan_, @ethicalhack3r, @erwan_lr, @firefart
_______________________________________________________________

[i] It seems like you have not updated the database for some time.
[+] URL: http://10.100.197.3/blog/ [10.100.197.3]
[+] Started: Wed Mar 25 13:25:03 2026

Interesting Finding(s):

[+] Headers
 | Interesting Entry: Server: Apache/2.4.29 (Ubuntu)
 | Found By: Headers (Passive Detection)
 | Confidence: 100%

[+] XML-RPC seems to be enabled: http://10.100.197.3/blog/xmlrpc.php
 | Found By: Direct Access (Aggressive Detection)
 | Confidence: 100%
 | References:
 |  - http://codex.wordpress.org/XML-RPC_Pingback_API
 |  - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpr
ess_ghost_scanner/
 |  - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_
```

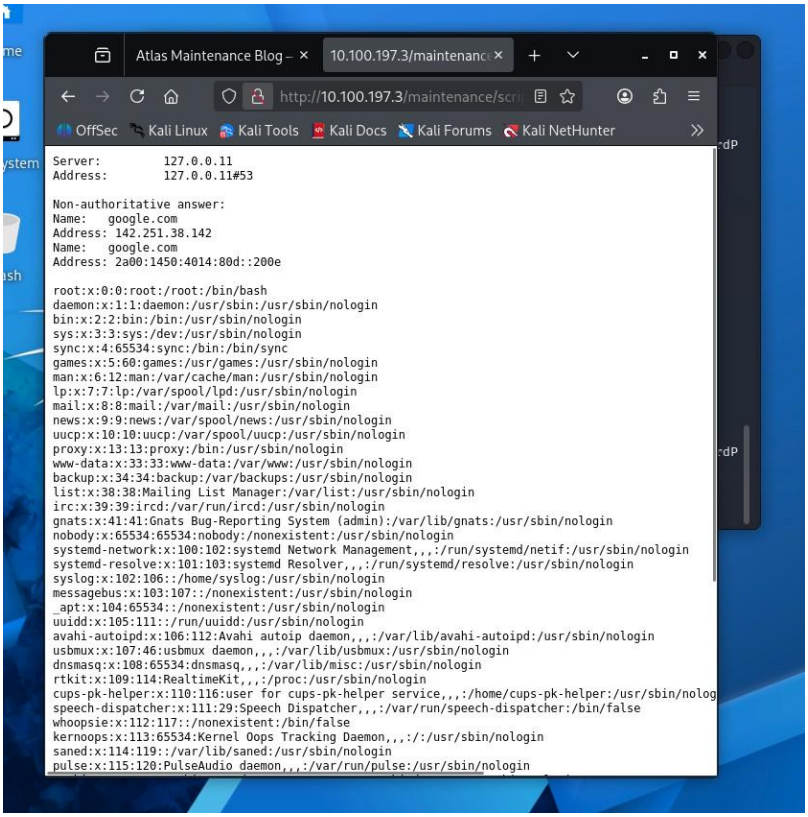


```
kali@up2278369: ~
Session  Actions  Edit  View  Help
Scapy 2.7.01   kali@up2278369: ~
 |  - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_
xmlrpc_dos/
 |  - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpr
ess_xmlrpc_login/
 |  - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpr
ess_pingback_access/

[+] WordPress readme found: http://10.100.197.3/blog/readme.html
 | Found By: Direct Access (Aggressive Detection)
 | Confidence: 100%

[+] Registration is enabled: http://10.100.197.3/blog/wp-login.php?ac
tion=register
 | Found By: Direct Access (Aggressive Detection)
 | Confidence: 100%

[+] Upload directory has listing enabled: http://10.100.197.3/blog/wp
-content/uploads/
 | Found By: Direct Access (Aggressive Detection)
 | Confidence: 100%

[+] The external WP-Cron seems to be enabled: http://10.100.197.3/blo
g/wp-cron.php
 | Found By: Direct Access (Aggressive Detection)
 | Confidence: 60%
 | References:
 |  - https://www.iplocation.net/defend-wordpress-from-ddos
 |  - https://github.com/wpscanteam/wpscan/issues/1299

[+] WordPress version 5.2.24 identified (Outdated, released on 2026-0
3-13).
 | Found By: Emoji Settings (Passive Detection)
 |  - http://10.100.197.3/blog/, Match: '-release.min.js?ver=5.2.24'
 | Confirmed By: Meta Generator (Passive Detection)
```

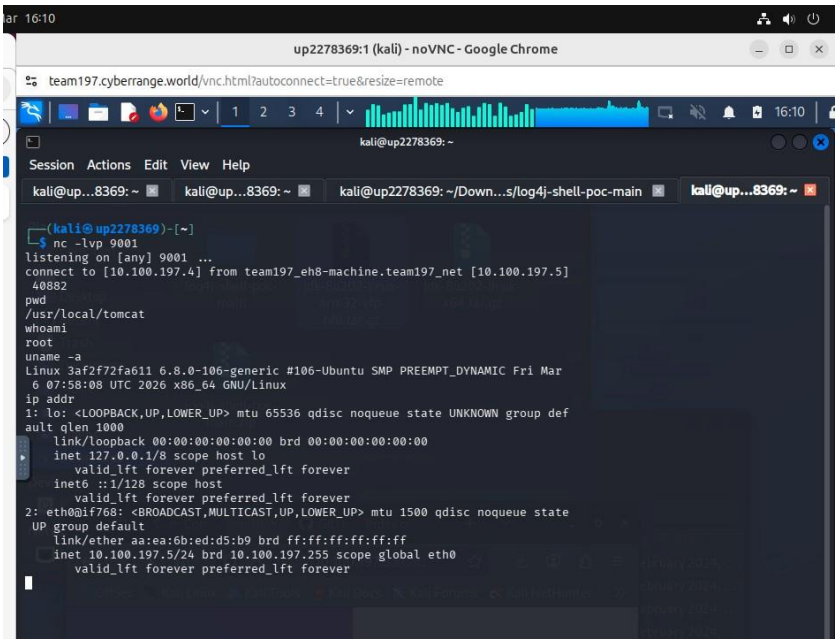
Q2 **Provide screenshots for steps above: uname -a output, whoami output, and /etc/passwd output.**


(kali㉿up2278369)-[~]
$ wpscan --url http://10.100.197.3/blog/
Trash
Atlas Maintenance
10.100.197.3/main
http://10.100.197.3/maintenan
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Server: 127.0.0.11
Address: 127.0.0.11#53
Non-authoritative answer:
Name: google.com
Address: 142.251.209.14
Name: google.com
Address: 2a00:1450:4014:800::200e
Linux 119200b17370 6.8.0-106-generic #106-Ubuntu SMP PREEMPT_DYNAMIC Fri Mar 6 07:
to be running


Trash
Atlas Maintenance
10.100.197.3/main
http://10.100.197.3/maintenan
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Server: 127.0.0.11
Address: 127.0.0.11#53
Non-authoritative answer:
Name: google.com
Address: 142.251.38.142
Name: google.com
Address: 2a00:1450:4014:80d::200e
www-data
to be running



Q3 **Run the commands above and take the results into your portfolio. Make sure that you show your CyberRange ID in the screenshot.**



Q4 **In this lab you obtained root reverse shell. On two different machines using two different vulnerabilities. What is the root cause that made both attacks possible? State one control that would have reduced the impact of either exploit.**

The root cause that made both attacks possible was the injection of program code/commands into the input fields of the individual websites, for example the JavaScript injected into the second site. One control that would reduce the impact would have been stronger input sanitization, which would have prevented/ restricted the commands being entered.